ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

Nombre: Angel Nicolas Cuervo Naranjo
David Salomon Baena Rubio

Fecha: 20/02/2026

Taller: Introducción a la Norma ISO 27000

1. ¿Qué es un Sistema de Gestión de Seguridad de la Información (SGSI) según la ISO/IEC 27001?

Un Sistema de Gestión de Seguridad de la Información (SGSI) es el conjunto de políticas, procesos, procedimientos, estructuras organizativas y recursos tecnológicos que una organización establece para gestionar y proteger su información de manera sistemática. Según la ISO/IEC 27001, su propósito central es preservar la tríada de la seguridad de la información

Objetivo: Comprender el concepto y los beneficios de implementar un SGSI.

- Investigar los componentes de un SGSI.
  1. Confidencialidad: garantizar que solo personas autorizadas accedan a la información.
  2. Integridad: asegurar que la información no sea alterada de forma no autorizada.
  3. Disponibilidad: garantizar el acceso oportuno a la información cuando sea necesario.

- Explicar cómo un SGSI puede proteger la confidencialidad, integridad y disponibilidad de la información en una empresa.

En una empresa como una entidad financiera, el SGSI se materializa en componentes concretos: una política de seguridad aprobada por la alta dirección, un inventario de activos de información (bases de datos de clientes, sistemas transaccionales, contratos), un proceso formal de gestión de riesgos, controles técnicos (cifrado, firewalls, MFA) y procedimientos de auditoría interna. La norma exige además que el alcance del SGSI esté delimitado, que exista un responsable de seguridad designado, y que se lleven registros demostrables del cumplimiento, lo que permite a la organización obtener la certificación ISO 27001.

2. ¿Cuáles son los principios de la gestión de riesgos de la información bajo la ISO/IEC 27005?

La ISO/IEC 27005 proporciona directrices para la gestión de riesgos de seguridad de la información, complementando a la ISO 27001. Su enfoque es proactivo: identificar amenazas antes de que se materialicen y tomar decisiones informadas para reducir la exposición al riesgo.

Objetivo: Comprender la importancia de una gestión proactiva de riesgos de la información.

- Definir los pasos clave en la identificación y evaluación de riesgos de seguridad.
  1. Establecimiento del contexto: definir los límites del análisis, los activos a proteger y los criterios de aceptación del riesgo.
  2. Identificación del riesgo: levantar un inventario de activos, identificar amenazas (ataques externos, errores humanos, fallos técnicos) y vulnerabilidades asociadas.
  3. Análisis y evaluación: estimar la probabilidad de ocurrencia e impacto para obtener un nivel de riesgo (alto, medio, bajo) y priorizar tratamiento.

4. Tratamiento del riesgo: aplicar controles para mitigar, transferir (seguros), aceptar o evitar el riesgo según el apetito de riesgo organizacional.
5. Monitoreo y revisión: revisar periódicamente que los controles sean efectivos ante nuevas amenazas.

- Investigar cómo la ISO/IEC 27005 guía a las organizaciones en la toma de decisiones para mitigar riesgos.

En una empresa de retail con e-commerce, la ISO 27005 guiaría a identificar que la base de datos de tarjetas de crédito es un activo crítico, que existe amenaza de inyección SQL y que la vulnerabilidad radica en un código sin validación de entradas. El riesgo resultante sería alto, por lo que se decidiría implementar un WAF, pruebas de penetración periódicas y cifrado de datos en reposo, priorizando inversión donde el impacto es mayor.

3. ¿Cómo el ciclo PDCA (Planificar, Hacer, Verificar, Actuar) apoya la mejora continua en un SGSI?

El ciclo PDCA (Plan-Do-Check-Act / Planificar-Hacer-Verificar-Actuar) es el motor de mejora continua que sostiene el SGSI. La ISO 27001 lo adopta como estructura base para asegurar que la seguridad no sea estática sino que evolucione con el entorno.

Objetivo: Entender cómo el ciclo PDCA asegura la evolución constante del sistema de seguridad.

- Explicar el ciclo PDCA y su aplicación en la seguridad de la información.
  1. Planificar (Plan): definir el alcance del SGSI, realizar el análisis de riesgos, establecer objetivos de control y seleccionar los controles del Anexo A que apliquen.
  2. Hacer (Do): implementar los controles seleccionados, ejecutar programas de concienciación, desplegar herramientas técnicas y documentar procedimientos operativos.
  3. Verificar (Check): realizar auditorías internas, medir la eficacia de los controles con KPIs (ej. tiempo de respuesta ante incidentes, número de brechas), revisar registros y evaluar cumplimiento.
  4. Actuar (Act): tomar acciones correctivas y preventivas ante las no conformidades detectadas, actualizar la evaluación de riesgos y mejorar políticas existentes.

- Investigar ejemplos de cómo las organizaciones aplican este ciclo para mejorar sus controles de seguridad.

Un hospital certificado en ISO 27001 detectó en la fase Verificar que el 30% de incidentes de seguridad tardaban más de 72 horas en resolverse, superando el SLA definido. En la fase Actuar implementó un playbook de respuesta a incidentes y automatizó alertas en el SIEM. En el siguiente ciclo Planificar, el tiempo de respuesta fue incluido como KPI crítico, reduciéndose al 85% de cumplimiento en el ciclo siguiente.

4. ¿Qué son los controles del Anexo A de la ISO/IEC 27001 y cómo pueden aplicarse en una empresa?

El Anexo A de ISO/IEC 27001:2022 contiene 93 controles organizados en 4 categorías: organizacionales (37), personas (8), físicos (14) y tecnológicos (34). Estos controles son el catálogo de salvaguardas que una organización puede implementar en función de sus riesgos identificados. No todos son obligatorios; su selección se justifica en la Declaración de Aplicabilidad (SoA).

Objetivo: Explorar los controles específicos que protegen los activos de información

- Investigar la función de los controles del Anexo A.
- Elegir algunos controles y explicar cómo se aplican en escenarios empresariales.

  - A.5.15 – Control de acceso: En una empresa de servicios financieros, se implementa el principio de mínimo privilegio: cada empleado accede únicamente a los sistemas necesarios para su rol. Los accesos privilegiados de administradores se gestionan con soluciones PAM (Privileged Access Management).

  - A.8.7 – Protección contra malware: En una empresa manufacturera con OT/IT convergente, se despliegan antivirus en endpoints, se restringe el uso de USB y se aplican políticas de actualización de parches mensuales.

  - A.5.24 – Gestión de incidentes de seguridad: En cualquier organización, se establece un proceso formal con roles definidos (equipo CSIRT), formularios de reporte, tiempos de respuesta y comunicación a reguladores si aplica (ej. Ley 1581 en Colombia).

  - A.8.24 – Uso de criptografía: En una plataforma de telemedicina, toda comunicación entre pacientes y médicos se cifra con TLS 1.3, y los registros médicos en base de datos se cifran con AES-256.

5. ¿Cuáles son los principales desafíos al implementar ISO 27001 en una organización y cómo superarlos?

La implementación de un SGSI bajo ISO 27001 presenta retos organizativos, técnicos y presupuestales que deben gestionarse estratégicamente para garantizar el éxito del proyecto.

Objetivo: Identificar soluciones a problemas reales al implementar un SGSI.

- Investigar barreras comunes como los costos, la resistencia interna y la falta de conocimiento técnico.
- Proponer estrategias prácticas para superar estos desafíos.

1. Costos elevados: la certificación implica inversión en consultoría, herramientas, auditorías externas y capacitación. Estrategia: priorizar controles de alto impacto primero (quick wins), escalar la inversión en fases, y presentar el ROI a la dirección en términos de reducción de riesgo de multas regulatorias y pérdidas por incidentes.
2. Resistencia interna al cambio: los empleados perciben los nuevos controles como burocracia o limitaciones. Estrategia: ejecutar campañas de concienciación adaptadas por rol, involucrar a líderes de área como champions de seguridad, y gamificar el aprendizaje con simulacros de phishing y recompensas.
3. Falta de conocimiento técnico: muchas PYMES no cuentan con personal especializado en seguridad. Estrategia: contratar un CISO virtual o consultor externo durante la implementación inicial, apoyarse en la ISO 27003 (guía de implementación) y formar internamente al equipo con certificaciones como ISO 27001 Lead Implementer.
4. Alcance mal definido: intentar cubrir toda la organización de golpe dispersa recursos. Estrategia: iniciar con un alcance piloto (ej. solo el área de TI o un proceso crítico),

6. Genere una lista de todos los capítulos adicionales a ISO 27001, ISO27002 e ISO 27005 y su objetivo.

ISO/IEC 27000: Proporciona el vocabulario, definiciones y visión general de toda la familia de normas. Es la norma de referencia de términos.

ISO/IEC 27003: Guía de implementación de un SGSI. Ofrece recomendaciones prácticas para establecer, implementar, mantener y mejorar el SGSI conforme a ISO 27001.

ISO/IEC 27004: Define directrices para la medición y evaluación del desempeño del SGSI. Ayuda a establecer métricas e indicadores (KPIs) de eficacia de los controles.

ISO/IEC 27006: Especifica los requisitos para organismos que certifican SGSIs. Es el estándar que deben cumplir las entidades de certificación (ej. Bureau Veritas, SGS).

ISO/IEC 27007: Proporciona directrices para la auditoría de SGSIs. Complementa la ISO 19011 aplicada al contexto de seguridad de la información.

ISO/IEC 27008: Guía para auditores sobre los controles de seguridad de la información. Se enfoca en la revisión técnica de los controles implementados.

ISO/IEC 27009: Especifica cómo crear normas sectoriales derivadas de ISO 27001, garantizando coherencia entre la norma base y sus extensiones específicas.

ISO/IEC 27010: Proporciona directrices para la gestión de seguridad de la información en comunicaciones intersectoriales, incluyendo compartición de información entre organizaciones.

ISO/IEC 27011: Guías de implementación de la ISO 27002 específicas para el sector de telecomunicaciones.

ISO/IEC 27013: Orienta la implementación integrada de ISO 27001 e ISO 20000-1 (gestión de servicios de TI), evitando duplicidades entre ambos marcos.

ISO/IEC 27014: Define principios y conceptos para el gobierno corporativo de la seguridad de la información, dirigido a la alta dirección y consejos de administración.

ISO/IEC 27017: Proporciona controles adicionales de seguridad para servicios en la nube, como extensión de ISO 27002 para entornos cloud.

ISO/IEC 27018: Establece controles para la protección de datos personales en servicios cloud, orientada a privacidad y cumplimiento del tipo GDPR.

ISO/IEC 27019: Guía de gestión de seguridad de la información para el sector de energía, especialmente para sistemas de control de procesos en utilities.

ISO/IEC 27021: Define las competencias requeridas para los profesionales de gestión de SGSIs, útil para el diseño de programas de formación y certificación personal.

ISO/IEC 27031: Proporciona directrices para la continuidad de negocio en TIC (Tecnologías de la Información y Comunicaciones), complementando los planes de BCP/DRP.

ISO/IEC 27032: Aborda la ciberseguridad desde una perspectiva de coordinación entre múltiples partes interesadas en el ciberespacio, incluyendo internet, seguridad web y social engineering.

ISO/IEC 27033: Serie de normas de seguridad en redes (en varias partes), que cubre conceptos de seguridad de redes, arquitecturas de referencia, y aseguramiento de redes específicas.

ISO/IEC 27034: Guía de seguridad en aplicaciones (AppSec), que define el marco para integrar seguridad en el ciclo de vida del desarrollo de software (SDLC).

ISO/IEC 27035: Define los principios y procesos para la gestión de incidentes de seguridad de la información, incluyendo detección, reporte, evaluación y respuesta.

ISO/IEC 27036: Proporciona directrices de seguridad para las relaciones con proveedores y cadena de suministro, crítico para la gestión de riesgo de terceros.

ISO/IEC 27037: Guía para la identificación, recolección, adquisición y preservación de evidencia digital, esencial en procesos forenses e investigaciones.

ISO/IEC 27038: Define especificaciones para la redacción digital de documentos, protegiendo la privacidad al compartir información sensible redactada.

ISO/IEC 27040: Proporciona guías de seguridad para sistemas de almacenamiento de información, incluyendo medios físicos, sistemas en red (SAN, NAS) y almacenamiento en nube.

ISO/IEC 27050: Define los procesos para el descubrimiento electrónico (eDiscovery) de información, incluyendo identificación, preservación, recolección y revisión de datos.

ISO/IEC 27070: Proporciona requisitos para establecer una raíz de confianza virtual (virtual root of trust) en entornos de computación en nube, habilitando hardware security modules en cloud.

ISO/IEC 27102: Guía de gestión de seguridad de la información para la suscripción de seguros cibernéticos, ayudando a las organizaciones a prepararse y gestionar pólizas de ciberseguro.

ISO/IEC 27110: Define los conceptos y principios del marco de ciberseguridad, orientado a proporcionar una referencia global para establecer programas de ciberseguridad